

Nota de Actualización Técnica

(v2.0)

Versión: 2.0 (Segura e Inteligente)

Fecha: Julio 2026

Destinatario: Administrador de
Sistemas

CHATBOT DE SECRETARÍA VIRTUAL - SALESIANAS
ZARAGOZA

1. Resumen de la Actualización

Esta nota técnica documenta los cambios arquitectónicos, mejoras de usabilidad (UX), blindaje de seguridad y optimizaciones de rendimiento aplicadas en la **versión 2.0** del asistente virtual de secretaría. El objetivo de esta versión ha sido segmentar el comportamiento por ciclos escolares (Infantil, Primaria, ESO, FP), optimizar las peticiones de Inteligencia Artificial (Gemini) y pulir de forma drástica el comportamiento del chatbot cuando opera de manera local/offline (sin IA).

2. Mejoras del Frontend (`chat.js` y `style.css`)

2.1. Selector Inicial de Etapas (UX Segmentada)

Al iniciar, el chat presenta un selector interactivo donde las familias eligen su ciclo (Infantil, Primaria, ESO o FP). Al hacerlo, el bot filtra y muestra de inmediato las FAQs específicas de ese bloque, pasando esta variable (`stage`) al backend para contextualizar las consultas libres.

- Se ha programado una opción rápida  `Cambiar de Etapa Escolar` en el pie de las FAQs para restablecer el ciclo en caliente sin refrescar el chat.

2.2. Buscador Local Semántico Difuso (Offline)

Para pulir las consultas de texto libre cuando el servidor de IA está apagado, se ha implementado un motor difuso inteligente local:

- Distancia de Levenshtein:** Una función matemática que mide diferencias

entre caracteres. Esto tolera erratas tipográficas del usuario (ej: `"sieta"` o `"siestas"` coincidirán correctamente con `"siesta"`).

- **Filtro de Stopwords:** Un listado en español que limpia y descarta artículos y preposiciones vacías (`"el"`, `"la"`, `"para"`, `"con"`), reduciendo el ruido.
- **Diccionario de Sinónimos:** Vincula términos equivalentes en secretaría (ej: `*admisión*` $\rightarrow$ `*matrícula*` $\rightarrow$ `*inscripción*`; `*excursiones*` $\rightarrow$ `*salidas*`; `*prácticas*` $\rightarrow$ `*FCT*`).
- **Sugerencias Inteligentes:** Si una búsqueda arroja coincidencia baja/ambigua, el bot ofrece hasta 3 botones de FAQs sugeridas relacionadas en lugar de dar un error.

2.3. Blindaje XSS basado en DOMParser

Se ha implementado una sanitización ultra-segura en `chat.js` utilizando la API nativa de `DOMParser` en un documento desconectado:

- Se aplica una lista blanca estricta de etiquetas permitidas para formatear respuestas (`strong`, `em`, `b`, `a`, `br`, `p`, `span`, `ul`, `li`).
- Se inspeccionan atributos y se neutraliza cualquier esquema malicioso (como `javascript:`, `data:` o `vbscript:` en enlaces `href`) sustituyéndolo por `#`.
- Se fuerza `rel="noopener noreferrer"` y `target="_blank"` en todos los enlaces hipervínculos salientes.

2.4. Accesibilidad ARIA (WCAG Compliance) y Control de Estados

- Se inyectaron atributos descriptivos ARIA en toda la interfaz (`aria-expanded`, `aria-controls`, `aria-label`, `role="log"`, `aria-live="polite"`).
- Se vinculan correctamente las etiquetas `<label>` con los inputs del formulario mediante atributos `for` e `id`.
- Se implementó una bandera de estado `isTyping` que bloquea e inhabilita temporalmente el input y los botones de FAQs durante la simulación de escritura del bot, previniendo duplicidades e inconsistencias en la conversación.

3. Mejoras del Backend (`servidor_ia.js`)

3.1. Optimización en Gemini (Caché de Modelos por Etapa)

Para optimizar la latencia en Express y reducir los tiempos de red, se implementó un mapa de **caché de instancias del modelo** (`modelsCache`) indexado por el ciclo escolar del usuario (Infantil, Primaria, ESO, FP, Global). Esto evita inicializar el SDK de Google Generative AI en cada llamada HTTP, cacheando las directrices de Prompt del sistema ya construidas.

- Se configuró una temperatura baja (`temperature: 0.15`) para garantizar consistencia y eliminar alucinaciones, limitando el tamaño máximo de respuesta a 800 tokens.

3.2. Rate Limiting Optimizada (Fixed Window O(1))

El rate limiter de protección contra DoS e inundaciones de peticiones por alumnos ahora opera con una lógica de ventana fija ligera de complejidad $O(1)$. Cuenta con un **Garbage Collector periódico** en Node (`setInterval` cada 5 minutos) para limpiar IPs inactivas, asegurando un consumo de memoria plano en producción.

3.3. Saneamiento RGPD a Prueba de Fallos en Logs

Antes de registrar las preguntas anónimas de los usuarios para el panel de analíticas, el backend las sana activamente con expresiones regulares mejoradas:

- **Emails:** Filtrado exacto con límites de palabra (`\b`).
- **Teléfonos:** RegExp avanzada que intercepta fijos y móviles españoles e internacionales en formatos con prefijos (+34, 0034, (+34)), espaciados y paréntesis variables.
- **Documentos de Identidad:** Anonimización automatizada de números de **DNI** y **NIE** de España (reemplazados por `[DNI-OCULTO]` y `[NIE-OCULTO]`).

3.4. Cabeceras OWASP de Endurecimiento de Servidor

Se configuran de forma nativa cabeceras HTTP de blindaje perimetral básico para producción:

```
res.setHeader('X-Content-Type-Options', 'nosniff');  
res.setHeader('X-Frame-Options', 'DENY');  
res.setHeader('X-XSS-Protection', '1; mode=block');  
res.setHeader('Referrer-Policy', 'no-referrer');
```

Además, se restringe la carga de las solicitudes Express entrantes a un máximo de **10kb** para anular exploits de DoS por desbordamiento de búfer en memoria.

4. Contenidos Oficiales Cargados (FP e Integraciones)

- Se cargó la URL oficial del proceso de admisión de FP de Aragón: educa.aragon.es/-/admissionfp, explicando que solo aplica a 1º curso, y que para 2º curso la reserva se realiza directamente de forma interna en el centro.
- Se detallaron los usos de las plataformas tecnológicas del colegio: **Alexia** (gestión de familias, asistencia y notas) y **Microsoft Teams / Office 365** (entorno de clase y tareas).
- Se documentaron los requisitos de promoción a 2º de FP (máximo de materias pendientes cuya carga lectiva total no supere **9 horas semanales**) y el límite de **2 repeticiones por módulo**.